

Sr. No.	Domain
1	Organization & Regulatory Applicability
2	Organization & Regulatory Applicability
3	Organization & Regulatory Applicability
4	Organization & Regulatory Applicability
5	Organization & Regulatory Applicability
6	Privacy Governance
7	Privacy Governance
8	Privacy Governance
9	Privacy Governance
10	Privacy Governance
11	Privacy Governance
12	Controller & Processor Assessment
13	Controller & Processor Assessment
14	Controller & Processor Assessment
15	Controller & Processor Assessment
16	Controller & Processor Assessment
17	Personal Data & Processing Activities
18	Personal Data & Processing Activities
19	Personal Data & Processing Activities
20	Personal Data & Processing Activities
21	Personal Data & Processing Activities
22	Personal Data & Processing Activities
23	Lawful Basis, Consent & Transparency
24	Lawful Basis, Consent & Transparency
25	Lawful Basis, Consent & Transparency
26	Lawful Basis, Consent & Transparency
27	Lawful Basis, Consent & Transparency
28	Lawful Basis, Consent & Transparency
29	Data Subject Rights
30	Data Subject Rights
31	Data Subject Rights
32	Data Subject Rights
33	Data Subject Rights
34	Privacy Risk Management
35	Privacy Risk Management
36	Privacy Risk Management
37	Privacy Risk Management
38	Privacy Risk Management
39	Privacy Risk Management
40	Privacy Risk Management
41	Privacy Risk Management
42	Third Party & Vendor Privacy
43	Third Party & Vendor Privacy
44	Third Party & Vendor Privacy

Assessment Criteria / Question
Has the organization identified all applicable privacy laws based on its operations?
Is the privacy implementation scope formally defined?
Are current and planned countries of operation identified?
Has the organization identified business units in scope?
Are regulatory changes periodically monitored?
Has a documented privacy governance framework been established?
Are privacy roles and responsibilities formally assigned?
Has a Privacy Officer/DPO (where applicable) been designated?
Are privacy policies and procedures documented and approved?
Is privacy awareness training conducted?
Is privacy compliance periodically reviewed?
Has the organization identified whether it acts as Controller/Fiduciary or Processor for each activity?
Are controller obligations documented?
Are processor obligations documented?
Are Controller-Processor responsibilities contractually defined?
Are sub-processors identified and governed?
Has the organization identified all processing activities involving personal data?
Is a personal data inventory maintained?
Are categories of personal data identified?
Are categories of data subjects identified?
Are data flows documented?
Are processing purposes documented?
Has a lawful basis been identified for applicable processing activities?
Is consent obtained where required?
Can consent be withdrawn easily?
Are consent records maintained?
Is a privacy notice provided?
Does the notice accurately describe processing activities?
Is a process established to manage privacy rights requests?
Are requests tracked?
Is identity verified before fulfilling requests?
Can data be corrected or deleted where required?
Are response timelines monitored?
Is ROPA maintained?
Is a DPIA process established?
Are high-risk processing activities assessed?
Is Privacy by Design applied?
Are privacy risks assessed periodically?
Are remediation actions tracked?
Is data minimization practiced?
Are purpose limitation principles applied?
Are vendors processing personal data identified?
Are vendor privacy assessments performed?
Are DPAs/BAAAs executed where applicable?

Applicable Regulations	Deliverable Triggered	Response	Evidence / Remarks
		Dropdown (YES/No/NA)	
GDPR, DPDPA, CCPA/CPRA	Regulatory Applicability		
GDPR, DPDPA, CCPA/CPRA	Scope Definition		
GDPR, DPDPA, CCPA	Regulatory Applicability		
GDPR, DPDPA, CCPA/CPRA	Scope Definition		
GDPR, DPDPA, CCPA/CPRA	Governance		
GDPR, DPDPA, CCPA/CPRA	Privacy Governance		
GDPR, DPDPA, CCPA/CPRA	Governance		
GDPR, DPDPA, ISO 27701	Governance		
GDPR, DPDPA, CCPA/CPRA	Policy Framework		
GDPR, DPDPA, CCPA/CPRA	Training		
ISO 27701, GDPR	Internal Review		
GDPR, DPDPA, CCPA/CPRA	Role Assessment		
GDPR, DPDPA	Controller Program		
GDPR, ISO27701	Processor Program		
GDPR, HIPAA	DPA		
GDPR, ISO27701	Vendor Assessment		
GDPR, DPDPA, CCPA/CPRA	ROPA		
GDPR, DPDPA, CCPA/CPRA	Data Inventory		
GDPR, DPDPA, CCPA/CPRA	Data Inventory		
GDPR, DPDPA, CCPA/CPRA	ROPA		
GDPR, DPDPA, CCPA/CPRA	Data Flow Mapping		
GDPR, DPDPA	ROPA		
GDPR, DPDPA	Lawful Basis		
GDPR, DPDPA, CCPA	Consent		
GDPR, DPDPA	Consent		
GDPR, DPDPA	Consent		
GDPR, DPDPA, CCPA/CPRA	Privacy Notice		
GDPR, DPDPA, CCPA/CPRA	Privacy Notice		
GDPR, DPDPA, CCPA	DSAR		
GDPR, DPDPA	DSAR		
GDPR, CCPA	DSAR		
GDPR, DPDPA	DSAR		
GDPR, DPDPA	DSAR		
GDPR, ISO27701	ROPA		
GDPR, ISO27701	DPIA		
GDPR	DPIA		
GDPR, ISO27701	PbD		
GDPR, DPDPA, CCPA/CPRA	Risk Assessment		
ISO27701	Remediation		
GDPR, DPDPA	Governance		
GDPR, DPDPA	Governance		
GDPR, DPDPA, CCPA/CPRA	Vendor Assessment		
GDPR, DPDPA, CCPA/CPRA	Vendor Assessment		
GDPR, HIPAA	DPA/BAA		

[illegible]

45	Third Party & Vendor Privacy
46	Third Party & Vendor Privacy
47	Data Lifecycle Management
48	Data Lifecycle Management
49	Data Lifecycle Management
50	Data Lifecycle Management
51	Security & Personal Data Breach Management
52	Security & Personal Data Breach Management
53	Security & Personal Data Breach Management
54	Security & Personal Data Breach Management
55	Security & Personal Data Breach Management
56	Cross Border Transfers
57	Cross Border Transfers
58	ISO/IEC 27701 Governance
59	ISO/IEC 27701 Governance
60	ISO/IEC 27701 Governance
61	Healthcare Privacy (HIPAA Readiness)
62	Healthcare Privacy (HIPAA Readiness)
63	Healthcare Privacy (HIPAA Readiness)

Are vendors periodically reviewed?
Are third-party data sharing arrangements documented?
Are retention periods defined?
Is secure disposal implemented?
Are backup retention requirements defined?
Is archival managed appropriately?
Are appropriate security controls implemented?
Is a breach response process established?
Are personal data breaches recorded?
Is breach notification managed?
Are security incidents periodically reviewed?
Are cross-border data transfers identified?
Are transfer safeguards documented?
Is a PIMS established?
Are privacy objectives and reviews conducted?
Are internal audits and management reviews planned?
Is PHI identified where applicable?
Have HIPAA Privacy & Security Rule requirements been assessed?
Are Business Associate Agreements identified where applicable?

GDPR, DPDPA, CCPA/CPI	Vendor Review		
GDPR, DPDPA, CCPA/CPI	Vendor Assessment		
GDPR, DPDPA, CCPA/CPI	Retention		
GDPR, DPDPA, CCPA/CPI	Retention		
ISO27701,HIPAA	Retention		
GDPR, DPDPA, CCPA/CPI	Retention		
GDPR, DPDPA, CCPA/CPI	TOMs		
GDPR, DPDPA, CCPA/CPI	Incident Response		
GDPR,DPDPA,HIPAA	Incident Response		
GDPR,DPDPA,HIPAA	Incident Response		
ISO27701	Review		
GDPR,DPDPA	TIA		
GDPR	TIA		
ISO27701	PIMS		
ISO27701	PIMS		
ISO27701	PIMS		
HIPAA	PHI Inventory		
HIPAA	HIPAA Gap		
HIPAA	BAA		

[illegible]